Actividad Integradora 2: administración de un centro de cómputo universitario

Este caso integra lo revisado en clase del curso Administración de Centros de Cómputo en un solo escenario. Cada estudiante lo desarrolla de forma individual, fuera del aula, y lo evalúa con la rúbrica de la sección 7.

1. Datos generales

El caso se entrega de forma individual con fecha máxima 1 de noviembre, a través de la plataforma de Blackboard.

2. Contexto institucional

La Universidad Regional Andina (URA) es una institución ficticia de 14.000 estudiantes y 1.100 funcionarios. Su centro de cómputo central da servicio a la matrícula en línea, al sistema académico, al sistema financiero y al correo institucional.

Componente	**Situación actual**
Sala de servidores	38 servidores físicos; clúster VMware de 3 hosts con unas 160 máquinas virtuales
Almacenamiento	2 cabinas SAN; respaldos en un servidor dedicado
Energía y clima	2 UPS de 40 kVA, generador diésel de 200 kVA, 2 unidades CRAC (Acondicionador de Aire para Salas de Cómputo)
Red	Firewall de nueva generación, switches de núcleo, enlace a Internet de 1 Gbps
Dispositivos IoT	42 sensores de temperatura y humedad, 8 PDU inteligentes y 30 cámaras IP en la red de operaciones
Laboratorios	6 laboratorios docentes con 240 equipos
Personal técnico	Director, 2 administradores de sistemas, 1 administrador de redes, 1 DBA a tiempo parcial, 3 operadores por turno y 2 técnicos de infraestructura física

El inventario se lleva en hojas de cálculo. GLPI *(software de código abierto (Open Source) para la gestión de servicios de TI (ITSM) y mesa de ayuda (Helpdesk))* se instaló en 2023, pero no está sincronizado con las compras. Zabbix no ha revisado sus umbrales desde 2024, y desde marzo un módulo de IA predice fallas de discos y fuentes de poder. La administración prometió a Admisiones una disponibilidad de 99,9 % para el portal de matrícula, y la universidad aspira a certificarse en ISO/IEC 27001 en dos años.

3. Escenario y cronología de hechos

Los hechos ocurren en tres semanas. Ninguno corresponde a una sola unidad: cada uno exige combinar varios temas del curso. Si necesita suponer datos adicionales (modelo de equipos, costos, nombres de personal), declárelos en el informe.

Semana	Hecho
1, lunes	El portal de matrícula queda fuera de servicio durante 6 horas por un ataque de denegación de servicio. El NOC no escaló el caso, y el primer aviso lo dio un estudiante en redes sociales.
1, martes	Una auditoría interna encuentra 37 equipos de laboratorio sin registro, 9 licencias de software sin soporte y un servidor retirado de bodega sin acta de baja.
1, jueves	Un atacante entra por una cámara IP con credenciales de fábrica (admin/admin), se mueve lateralmente y llega a un host de virtualización. La actividad se detecta dos días después en los logs del hipervisor.
2, martes	Falla una fuente de poder de un servidor. El módulo de IA no la había anticipado; la revisión muestra que dos sensores de temperatura reportaron valores constantes durante tres semanas.
2, jueves	Un phishing roba la credencial de un administrador. Se intenta cifrar el servidor de respaldos, que no era inmutable, y se recupera el 80 % de la información.
2, viernes	La prueba del generador falla por batería descargada. Durante la prueba, el UPS de la sala queda con 12 % de autonomía.
3, lunes	El único especialista en VMware solicita traslado y no hay personal que lo reemplace de inmediato.
3, miércoles	El ente de control solicita, en 15 días, evidencias de inventario, plan de recuperación ante desastres, gestión de cambios y registros de incidentes.

4. Actividades

Cada ítem tiene preguntas guía. Responda todas, con el análisis en el cuerpo del informe y las evidencias en los anexos.

Ítem 1. Inventario, control y mantenimiento de hardware y software

1. Diseñe el proceso para registrar los 240 equipos de laboratorio y los 37 no registrados. Defina los campos mínimos del registro: ubicación, responsable, fecha de adquisición, código o etiqueta, historial y estado.
2. Justifique la herramienta de inventario que recomienda (GLPI con OCS Inventory, Lansweeper, etiquetas QR u otra), con criterios de costo, mantenimiento y auditoría.

Ítem 2. Monitoreo y administración de redes y servicios

1. Calcule el tiempo de caída anual permitido para 99,9 %, 99,99 % y 99,999 %. Indique si el SLA prometido a Admisiones era realista, considerando el evento de 6 horas.
2. Defina las métricas de disponibilidad, latencia, tasa de errores y uso de recursos para el portal de matrícula y para la red. Proponga umbrales de advertencia y críticos.
3. Diseñe la matriz de escalamiento de Nivel 0 a Nivel 3: quién atiende, en cuánto tiempo, con qué manual de actuación y con qué herramienta (guardias, tickets). Aplique la matriz al ataque de denegación de servicio.

Ítem 3. Gestión del recurso humano técnico

1. Analice la estructura de roles del centro frente a la operación 24/7. Identifique roles sobrecargados o inexistentes y proponga una estructura mínima.
2. Construya una matriz de habilidades para el equipo, con al menos 7 personas ficticias, y diagnostique el riesgo de persona clave única en VMware y en la base de datos.
3. Defina cuatro indicadores de desempeño (por ejemplo, MTTR, resolución en primera llamada, reaperturas y cumplimiento de procedimientos), con metas numéricas. Incluya un plan de desarrollo individual para uno de los técnicos.

Ítem 4. Seguridad en IoT e IA para administradores de centros de cómputo

1. Clasifique los dispositivos IoT del caso (cámaras, PDU, sensores y CRAC) por riesgo. Para cada uno, indique la falla de seguridad más probable y la medida de endurecimiento (hardening).
2. Explique cómo la cámara IP permitió el movimiento lateral.
3. Analice tres riesgos de IA aplicados al caso: evasión de SIEM, envenenamiento de datos del modelo predictivo y manipulación de la optimización de cargas.
4. Proponga controles para la IA: auditoría de caja negra, verificación de integridad de los datos con hashes, monitoreo del drift del modelo y criterios para desactivarlo o reentrenarlo.

Ítem 5. Ciberseguridad en redes e infraestructuras críticas

1. Clasifique las amenazas del caso en físicas, lógicas y humanas. Indique cuáles se materializaron y cuáles quedan abiertas.
2. Proponga una solución de gestión de accesos privilegiados (PAM) para los administradores, con bóveda, grabación de sesiones y cambio automático de contraseñas.

5. Plan integrador

Consolide sus hallazgos de los cinco ítems en un plan de intervención de 90 días. Este plan es la parte que más pesa en la evaluación, porque muestra si sabe priorizar.

1. Liste todos los hallazgos y asígneles impacto y esfuerzo. Ubíquelos en una matriz de dos ejes (impacto y esfuerzo).
2. Para cada acción del plan, indique el responsable (por rol), las fechas de inicio y fin, un costo aproximado en orden de magnitud y un indicador de éxito.
3. Identifique tres riesgos de la implementación (por ejemplo, falta de presupuesto, resistencia del personal o dependencia de un proveedor) y su respuesta.

4. Relacione cada acción con la evidencia que la universidad presentaría al ente de control o en una auditoría ISO/IEC 27001.
5. Cierre con una reflexión de una página: qué aprendió del caso y qué limitaciones tiene su propuesta.

Una estructura posible para el plan es:

- **Días 0 a 30:** contención y diagnóstico de los riesgos más urgentes.
- **Días 31 a 60:** corrección de causas raíz en seguridad, monitoreo e inventario.
- **Días 61 a 90:** estandarización de procesos, capacitación y primera prueba del plan de recuperación.

6. Entregables y condiciones

El informe se entrega en PDF, en la fecha indicada. Los entregables son:

- **Informe escrito**, de 8 a 10 páginas, con portada, índice, desarrollo por ítems, plan integrador, reflexión final y referencias.
- **Anexos**, que pueden ir después de las referencias: registro de activos de muestra (mínimo 10 filas), cronograma de mantenimiento, matriz de habilidades, tabla de umbrales, matriz de escalamiento, inventario IoT con versión de firmware y plan de recuperación.
- **Formato**: citas y referencias en APA 7.

Condiciones:

- El trabajo es individual. Puede consultar material del curso y fuentes externas, pero debe redactar y argumentar sus propias soluciones.
- Si usa herramientas de IA, declárelo en un anexo: qué herramienta usó, para qué tarea y qué verificó después.
- Use al menos seis fuentes, de las cuales tres deben ser documentación oficial de herramientas o normas. Las presentaciones del curso no cuentan como fuente externa.
- Los supuestos que agregue al escenario deben declararse en la sección de datos del caso.

7. Rúbrica de evaluación

Cada criterio se califica con uno de cinco niveles. El puntaje del criterio es su peso multiplicado por el porcentaje del nivel. La nota suma 100 puntos y se pasa a escala de 0 a 10 dividiendo entre 10.

Criterio (peso)	Excelente (100 %)	Competente (75 %)	En desarrollo (50 %)	Insuficiente (25 %)	No presenta (0 %)
C1. Diagnóstico integral (10 pts)	Identifica y prioriza hallazgos de las cinco unidades, con evidencia del caso y causa raíz.	Identifica hallazgos de las cinco unidades; algunas causas raíz quedan sin explicar.	Cubre tres o cuatro unidades; el análisis es sobre todo descriptivo.	Cubre una o dos unidades, o solo repite los hechos.	No presenta diagnóstico.

Criterio (peso)	Excelente (100 %)	Competente (75 %)	En desarrollo (50 %)	Insuficiente (25 %)	No presenta (0 %)
C2. Inventario, control y mantenimiento (U1) (10 pts)	Registro con campos mínimos, proceso de baja, cronograma preventivo y correctivo trazable, y herramienta justificada.	Registro y mantenimiento correctos, con una omisión menor.	Propuesta genérica, con poca trazabilidad o sin justificar la herramienta.	Menciona el tema sin una propuesta aplicable al caso.	No responde esta unidad.
C3. Monitoreo, disponibilidad y rendimiento (U2) (10 pts)	Cálculo correcto de caídas permitidas, métricas con umbrales de advertencia y críticos, y reducción de ruido por dependencias.	Métricas y umbrales correctos; el cálculo o la reducción de ruido están incompletos.	Define métricas sin umbrales o sin relación con el SLA.	Confunde disponibilidad con rendimiento, o los cálculos son erróneos.	No responde esta unidad.
C4. Escalamiento e incidentes (U2) (8 pts)	Matriz N0 a N3 con tiempos, roles, herramientas de guardia y post mortem, aplicada al ataque.	Niveles y herramientas correctos; tiempos o aplicación al caso parciales.	Niveles sin criterios claros de escalamiento ni aplicación al caso.	Escalamiento poco coherente con el caso.	No responde esta unidad.
C5. Recurso humano técnico (U3) (12 pts)	Estructura 24/7 justificada, matriz de habilidades, turnos, formación cruzada, indicadores con metas y	Roles y matriz correctos; indicadores o turnos con imprecisiones.	Lista roles sin analizar carga de trabajo ni riesgo de persona clave.	Propuesta de personal sin relación con la operación.	No responde esta unidad.

Criterio (peso)	Excelente (100 %)	Competente (75 %)	En desarrollo (50 %)	Insuficiente (25 %)	No presenta (0 %)
	plan de desarrollo individual.				
C6. Seguridad en IoT (U4) (10 pts)	Clasifica dispositivos por riesgo, explica el pivote, propone VLAN aislada con firewall o endurecimiento.	Clasificación y segmentación correctas.	Medidas genéricas, sin relación con los dispositivos del caso.	Menciona IoT sin propuesta de control.	No responde esta unidad.
C7. Riesgos de IA en operaciones (U4) (8 pts)	Analiza evasión de SIEM, envenenamiento de datos y manipulación de cargas, con controles (hashes, drift, caja negra) aplicados al caso.	Analiza dos riesgos de IA, con controles parciales.	Riesgos de IA genéricos, sin relación con el caso.	Menciona la IA sin análisis de riesgo.	No responde esta unidad.
C8. Ciberseguridad, perímetro y continuidad (U5) (12 pts)	Clasifica amenazas; propone controles físicos, lógicos y humanos; zero trust, PAM y DRP con RTO, RPO.	Controles correctos en dos de las tres capas	Controles genéricos	Lista amenazas sin propuesta de control.	No responde esta unidad.
C9. Plan integrador y priorización (10 pts)	Plan de 90 días con matriz impacto-esfuerzo, responsables, costos de	Plan completo con prioridades claras; faltan costos o indicadores en	Acciones sueltas, sin prioridad ni responsables.	Plan que no responde a los hallazgos.	No presenta plan.

Criterio (peso)	Excelente (100 %)	Competente (75 %)	En desarrollo (50 %)	Insuficiente (25 %)	No presenta (0 %)
	orden de magnitud, indicadores y riesgos.	algunas acciones.			
C10. Calidad técnica, redacción y fuentes (10 pts)	Redacción clara, estructura completa, al menos seis fuentes en APA 7 y terminología correcta.	Redacción clara con errores menores; citas con omisiones leves.	Redacción confusa, o menos de seis fuentes.	Texto sin estructura ni citas.	No entrega informe.

Total: 100 puntos.

Por ejemplo, Excelente en C1 (10 pts), Competente en C2 (7,5 pts) y En desarrollo en C3 (5 pts) suman 22,5 puntos de los 30 que valen esos tres criterios.

8. Referencias

- International Organization for Standardization. (2022). *ISO/IEC 27001: Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de la seguridad de la información.*
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0.*
- Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *NIST SP 800-207: Zero Trust Architecture.*
- Grance, T., Nolan, T., Burke, K., Dudley, R., White, G. y Hash, J. (2010). *NIST SP 800-34 Rev. 1: Contingency Planning Guide for Federal Information Systems.*
- AXELOS / PeopleCert. (2019). *ITIL 4 Foundation.*
- Beyer, B., Jones, C., Petoff, J. y Murphy, N. R. (eds.). (2016). *Site Reliability Engineering.* O'Reilly.
- Documentación oficial de las herramientas que use (por ejemplo, Zabbix, GLPI, Grafana o el fabricante de su firewall).